INSPECCO × KRIPTARIUM

Safety 4.0 Bootcamp

Laboratuvar Föyleri — Kantec Sürümü · Robotik Sorter & Paletleyici / ROBOTEGG

Tüm laboratuvarlar Kantec'in robotik yumurta paletleyicisine (ROBOTEGG hattı) uyarlanmıştır: Yaskawa GP225 robot (225 kg) · 4 palet istasyonu · Siemens PLC · üretim izleme yazılımı · üreticinin sunduğu uzaktan erişim.

LAB 1 · Safety Architecture	Çıktı: Safety Function Map
LAB 2 · IEC 62443 Mini Workshop	Çıktı: Zone / Conduit Diagram
LAB 3 · Threat & Risk + Risk Matrix	Çıktı: Risk Register
LAB 4 · Secure Remote Access	Çıktı: Secure Architecture
LAB 5 · SBOM / CVE / Patch	Çıktı: Vulnerability Decision
LAB 6 · CRA Incident Simulation	Çıktı: Incident Workflow
LAB 7 · AI Safety Challenge	Çıktı: AI Fail-Safe Decision

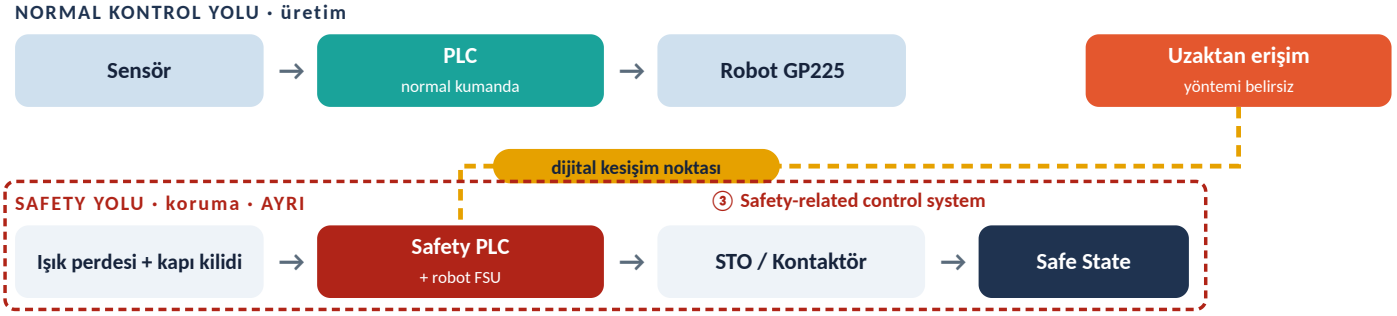
Bu föyler bir eğitim çıktısıdır; resmî denetim, uygunluk değerlendirmesi veya belgelendirme değildir ve CE/mevzuat uygunluğu garantisi vermez. Doldurduğunuz föyler gün sonunda Machine Starter Pack'inizi oluşturur ve Safety 4.0 Workspace'te yaşamaya devam eder.

Safety Architecture

Çıktı: Safety Function Map

Ad Soyad **Kumru Çelik** | Grup | Tarih

Kantec bağlamı: 225 kg taşıyan **Yaskawa GP225** robot ve forkliftin girdiği **4 palet istasyonu** ezilme tehlikesidir; koruma **kapı kilidi + ışık perdesi → Safety PLC / FSU → servo kesme** zinciridir. Üretici bu hat için **uzaktan erişim** sunuyor — sorular oraya gidecek.



Görev — sırayla cevaplayın

1. **Bu makinede tehlike nedir? İnsan neyden zarar görür?**
   Tehlike, 225 kg yük taşıyan ve hızlı dönen Yaskawa GP225 robot koludur: çarpma, ezilme, sıkışma ve tutucudan düşen yük. En kritik yer palet istasyonlarıdır: forklift operatörü dolu paleti alırken robot diğer kapılarda çalışmaya devam eder. Konveyörlerde de sıkışma noktaları vardır.

2. **Safety function (emniyet fonksiyonu) hangisidir?**
   SF1: kapı kilidi açılırsa veya E-stop'a basılırsa robot ve konveyör güvenli durur. SF2: bir palet istasyonunun ışık perdesi kesilince robotun o istasyona girmesi FSU alan sınırlamasıyla engellenir. Yeniden başlatma yalnızca manuel reset ile olur.

3. **Safety-related control system nerede? Şemada işaretleyin.**
   Şemada kırmızı çerçeveli SAFETY YOLU: kapı kilidi + ışık perdesi + E-stop → Safety PLC (F-CPU) + robot FSU → servo enerjisinin kesilmesi. Siemens hücre PLC'si, üretim izleme yazılımı ve WMS bu sistemin parçası değildir.

4. **Normal PLC ile Safety PLC farkı nedir?**
   Normal PLC üretimi yönetir: sipariş, palet deseni, kapı seçimi; tek kanallıdır, kolay değişir. Safety PLC / FSU PL/SIL sertifikalıdır, çift kanallıdır, kendini test eder; ayarları şifreli Safety Mode ve CRC checksum (bütünlük değeri) ile korunur.

5. **PLr / SIL neden var? Bu fonksiyon için neden önemli?**
   Risk büyüdükçe emniyet fonksiyonu daha güvenilir olmalıdır; PLr (ISO 13849-1) ve SIL bunun ölçüsüdür. Burada yaralanma ağır olabilir, forklift sürücüsü istasyona sık girer ve koldan uzaklaşmak zordur → hedef PL d / Kategori 3 (ISO 10218-2). Kesin değeri risk değerlendirmesi belirler.

6. **Safe state (güvenli durum) nedir?**
   Robot servoları enerjisiz ve frenler kapalı, konveyör duruyor, tutucu yükü bırakmıyor. Hücre manuel reset yapılmadan kendiliğinden yeniden çalışmaz.

7. **Safety function hangi dijital bağımlılıklara sahip?**
   FSU alan / hız / tutucu ayarları + Safety Mode şifresi + CRC değeri · Safety PLC programı · YRC1000 robot kontrolcüsü ve Siemens firmware'i · PROFIsafe güvenlik ağı · programlama yazılımları (TIA Portal, Yaskawa araçları) · uzaktan erişim yolu.

8. **Siber müdahale hangi noktadan bu fonksiyonu bozar?**
   Dijital kesişim noktası = hattın uzaktan erişimidir. Bu yol yeterince korunmazsa Siemens PLC'ye veya robot kontrolcüsüne ulaşan biri FSU alan sınırını değiştirebilir ya da "kapı boş" bilgisini bozabilir. Fiziksel sonuç: robot, forkliftin bulunduğu istasyona girebilir ve operatör zarar görür.

Bu föyün çıktısı **Safety Function Map** → Evidence Pack **EP 03 Safety Functions** başlığına oturur.

LABORATUVAR 2 · KANTEC · Robotik Sorter & Paletleyici / ROBOTEGG

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad **Kumru Çelik** | Grup | Tarih

Kavram: Zone = benzer kritiklikteki cihazları bir bölgeye topla. **Conduit** = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz — mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi

Siemens hücre PLC'si · **Emniyet PLC'si + robot FSU** · YRC1000 robot kontrolcüsü · üretim izleme yazılımı / HMI · konveyör sürücüleri · **uzaktan erişim (yöntemi yayımlanmamış)** · WMS / ERP bağlantısı · görüntü işleme kamerası · mühendislik istasyonu · teach pendant

1. Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

   Z1 Kurumsal (SL1): WMS/ERP. Z2 DMZ (SL3): uzaktan erişim noktası, jump server, veri aktarımı. Z3 Operasyon (SL2): üretim izleme/HMI. Z4 Mühendislik (SL3): TIA Portal, robot programlama. Z5 Hücre (SL2–3): Siemens PLC, YRC1000, konveyör, kamera. Z6 Safety (SL3): Emniyet PLC'si + robot FSU, kapı kilidi, ışık perdeleri, E-stop.

2. Uzaktan erişim noktası hangi bölgeye düşüyor — ve orada KALABİLİR Mİ? Neden?

   Yöntemi yayımlanmadığı için büyük olasılıkla doğrudan hücre ağına (Z5) bağlı. Orada KALAMAZ: internetten gelen biri PLC'ye, oradan emniyet ayarlarına ulaşabilir. DMZ'ye (Z2) taşınmalı ve hücreye yalnızca firewall'lu, kontrollü bir conduit üzerinden bağlanmalıdır.

3. Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?

   İnternet→Z2: VPN+MFA, kişisel hesap, kayıt, varsayılan kapalı. Z1 ↔ Z2 ↔ Z3: sipariş/sevkiyat verisi yalnız DMZ aktarım sunucusundan. Z3→Z5: çoğunlukla okuma (OPC UA). Z4→Z5: onaylı program yükleme. Z5 ↔ Z6: yalnız PROFIsafe; FSU/Safety PLC yalnız yerinde ve şifreyle değişir, CRC kontrol edilir; uzaktan safety yazma yok.

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	**Jump server** — tek, denetlenebilir kapı; doğrudan bağlantı tüm hücreyi açar.
Tünel?	Açık / VPN	**VPN** — internete açık port sürekli taranır.
Kimlik?	Parola / MFA	**MFA** — çalınan parola tek başına yetmez.
Hesap?	Paylaşılan / Kişisel	**Kişisel** — her Kantec mühendisi ayrı izlenir; ayrılanın erişimi kapanır.
Kayıt?	Yok / Tam oturum kaydı	**Tam oturum kaydı** — CRA bildirimi için kanıt sağlar ve caydırır.
Zamanlama?	Sürekli açık / Varsayılan kapalı	**Varsayılan kapalı** — müşteri onayıyla ve süreli açılır.

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.

Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad **Kumru Çelik** | Grup | Tarih

Kavram: Senaryo beş parçadır: **kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç**. Skor = L × S × E (her biri 1–3). **Kural:** S=3 ise skor düşük olsa bile senaryo öne alınır — insana zarar görünür kalır.

Kantec hücresinin kapıları (ipucu)

Uzaktan erişim (yöntemi yayımlanmamış) · WMS / ERP bağlantısı · üretim izleme sunucusu / HMI · mühendislik istasyonu · teach pendant ve Safety Mode şifresi · konveyör / kamera ağı — *fiziksel sonuç adayları: palet istasyonunda forklift operatörünün ezilmesi, robot çarpması, konveyörde sıkışma.*

Görev — üç senaryo kurun ve puanlayın

Senaryo (kim→kapı→zincir→fiziksel sonuç)	L	S	E	Skor	Öncelik
Dış aktör → korumasız uzaktan erişim → PLC'ye ulaşıp "kapı boş" bilgisini bozar; FSU ayarı zayıfsa alan sınırı da genişler → robot, forkliftin olduğu istasyona girer → **operatör ezilir**	2	3	3	18	Kritik
Fidye yazılımı → ofis ağındaki WMS/ERP → üretim izleme ve HMI kilitlenir → hat elle kurtarılmaya çalışılır → **konveyörde sıkışma**	2	2	2	8	Orta
Yetkisiz iç kullanıcı → teach pendant + paylaşılan Safety Mode şifresi → FSU hız limiti değişir, CRC fark edilmez → bakımda robot beklenmedik hareket eder → **çarpma**	1	3	1	3	Düşük → öne alınır

Kritik 18–27 | **Yüksek 9–17** | **Orta 4–8** | **Düşük 1–3**

1. En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?

   Senaryo 1. Uzaktan erişim ilan edilmiş ama koruması belirsiz, forklift operatörü her vardiya istasyona girer ve sonuç ağır olabilir.

2. S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?

   Evet, Senaryo 3: skor 3 ama şiddet 3. Risk kaydında "S=3 bayrağı" ile işaretlenir ve önceliği şiddete göre verilir. Ayrıca CRC değerinin her vardiya başı kontrolü günlük kontrol listesine eklenir.

Altın kural: Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir — bir adım daha gidin: bu, hattaki insana ne yapar?

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.

LABORATUVAR 4 · KANTEC · Robotik Sorter & Paletleyici / ROBOTEGG

Secure Remote Access

Çıktı: Secure Architecture

Ad Soyad **Kumru Çelik** | Grup | Tarih

Kavram: İki katman, ikisi de şart: **erişim güvenliği** (girişi zorlaştır: ara nokta, VPN, MFA, kişisel hesap, kayıt, varsayılan kapalı) + **emniyet bağımsızlığı** (girse bile insan korunur).

Görev A — mevcut → hedef

MEVCUT (çizin/yazın)

İpucu: üretici uzaktan erişim sunuyor; koruması belirsiz.

Kantec servisi → internet → yöntemi belirsiz uzaktan erişim → Siemens hücre PLC'si ve robot kontrolcüsü. MFA, kişisel hesap ve oturum kaydı hakkında bilgi yok.

HEDEF (beş ilkeyle yeniden tasarlayın)

Kantec mühendisi → **VPN + MFA** → DMZ'deki **jump server** → firewall → yalnız hücre PLC'si ve izleme sunucusu.

- kişisel hesap
- tam oturum kaydı
- varsayılan kapalı, süreli
- FSU / Safety PLC'ye uzaktan erişim yok

Görev B — functional safety köprüsü

1. Saldırgan tüm önlemlere rağmen içeri girerse: emniyet fonksiyonu etkilenir mi? Neden?

   FSU ve Safety PLC ayrı bölgedeyse ve ayarları yalnız yerinde değişiyorsa etkilenmez: kapı kilidi ve ışık perdesi robotu yine durdurur. Saldırgan yalnız üretimi bozabilir (yanlış palet deseni, duran hat).

2. Işık perdesi zincirinin uzak bakım yolundan etkilenmemesi için GEREKSİNİMİ yazın (çözümü değil).

   Palet istasyonu ve robot hücresi emniyet fonksiyonları, normal kontrol sistemi veya uzaktan erişim yolu ele geçirilse bile tehlikeli hareketi durdurmaya devam etmelidir. Emniyet ayarları ve programı ağ üzerinden değiştirilememeli; her değişiklik bir CRC değeriyle tespit edilebilir olmalıdır.

Tarafsızlık notu: Bu föy çözüm tasarlatmaz; gereksinimi tanımlatır. Tasarım kararı firmanızındır.

Bu föyün çıktısı **Secure Architecture** → Evidence Pack **EP 02 + EP 06** başlığına oturur.

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad **Kumru Çelik** | Grup | Tarih

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	Component X (PLC firmware kütüphanesi) — örnek
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)
   Üç şartı kontrol ederim: bileşen var mı (SBOM'da Siemens firmware içinde Component X), sürüm etkileniyor mu (Siemens ProductCERT'teki aralıkla karşılaştır), açık ulaşılabilir mi (uzaktan erişim yolu PLC'ye açıksa evet). Üçü de sağlanırsa etkiler.
2. Üretimi hemen durdurur musunuz? Neden / neden değil?
   Hayır. Önce uzaktan erişimi kapatır, firewall'u sıkılaştırırım. Saldırı belirtisi görürsem hücreyi durdururum.
3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?
   Önce test. Kantec ile birlikte aynı firmware'e sahip test PLC'sinde ya da PLCSIM'de denenir, sonra planlı bir duruşta uygulanır.
4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?
   Yama Safety PLC'ye veya F-CPU firmware'ine dokunuyorsa etkiler. Bunu yama notundan ve safety programının imza/CRC değerinden anlarım; değişmişse kapı kilidi, ışık perdesi ve E-stop testleri yeniden yapılır.
5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?
   PLC ayrı bölgede izole edilir, firewall'da yalnız gerekli portlar açılır; uzaktan erişim varsayılan kapalı tutulur; PLC "RUN" kilidinde (programlama koruması açık) tutulur; ağ trafiği izlenir.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.

LABORATUVAR 6 · KANTEC · Robotik Sorter & Paletleyici / ROBOTEGG

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad **Kumru Çelik** | Grup | Tarih

Senaryo: Saat 10:15. Kantec uzaktan erişim hesabına gece 03:00'te tanınmayan bir IP'den girilmiş. PLC ve robot ayarları değişmiş olabilir; **ışık perdesi / FSU parametreleri henüz doğrulanmadı**. Hücre çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1. **10:15 — ilk 15 dk:** Kimi ararsınız? İlk üç eyleminiz?
   10:15–10:30: bakım/otomasyon sorumlusu, OT güvenlik sorumlusu, üretim müdürü ve Kantec servisi aranır. ① Hücre kontrollü durdurulur, forkliftler istasyonlardan uzak tutulur. ② Uzaktan erişim kesilir. ③ Hiçbir şey resetlenmez; saat ve gözlemler not edilir.

2. **İlk 2 saat:** Emniyet güvende mi — nasıl doğrularsınız? Hangi kanıt korunur? Hangi hesap kapatılır?
   Emniyet: teach pendant'tan FSU CRC değeri okunur ve onaylı kayıtla karşılaştırılır; Safety PLC imzası kontrol edilir; kapı kilidi, ışık perdesi ve E-stop fiziksel test edilir — doğrulanana kadar hücre çalışmaz. Kanıt: 03:00 girişinin logları ve IP'si, PLC ve robot ayarlarının kopyası (YRC1000 yedeği), firewall logları saklanır. Hesap: uzaktan erişim hesabı kapatılır, paylaşılan parolalar değişir.

3. **24 saat — CRA erken uyarı:** Hangi bilgi hazır olmalı?
   Tespit zamanı, yetkisiz giriş, etkilenen ürün ve sürümler, emniyete olası etki ve ilk önlemler.

4. **72 saat — CRA bildirim:** Kök neden, etki, önlem — kim ne yapıyor?
   Güvenlik ekibi kök nedeni bulur (ör. MFA'sız uzaktan erişim); otomasyon ekibi etkiyi belirler (FSU/PLC değişti mi); Kantec ve yönetim önlemleri (DMZ, VPN+MFA, kişisel hesap) belirler ve bildirimi gönderir.

5. **14 gün — son rapor:** Hangi loglar/kayıtlar korunmuş olmalı?
   Uzaktan erişim ve VPN logları, PLC ve robot değişiklik logları, CRC ve imza geçmişi, yedekler, yeniden doğrulama test kayıtları ve olay zaman çizelgesi.

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.

AI Safety Challenge

Çıktı: AI Fail-Safe Decision

Ad Soyad **Kumru Çelik** | Grup | Tarih

Kavram — Prediction ≠ Safety: Yapay zekâ bir karar üretir; güvenliği garanti eden mimari YZ'nin **dışında** tanımlanmalıdır.
Araçlar: fail-safe · human override · monitoring · confidence threshold · fallback.

Senaryo: Kantec ROBOTEGG hattına YZ'li görsel yumurta/viyol kontrolü eklenmesi planlanıyor — proje aşaması değerlendirmesi yapıyorsunuz.

Kamera → YZ Modeli → OK / RED → Ret mekanizması → Hat hızı

Görev — üç başarısızlıkta güvenli davranış

1. **Model yanlış sınıflandırdı:** Kusurlu parçaya OK verdi. Sistem ne yapmalı? İkinci kontrol / insan onayı var mı?
   Bu bir kalite hatasıdır, emniyet hatası değildir. Sevkiyat öncesi ikinci bir kontrol olmalı (ör. çatlak/ağırlık kontrolü) ve palet başına örnekleme ile insan onayı yapılmalı. Robotu durduran emniyet zinciri (ışık perdesi, FSU) YZ'den bağımsız kalır.

2. **Girdi manipüle edildi:** Kamera verisi bozuk/sahte. Nasıl fark edilir? Şüpheli girdide ne yapılır?
   Görüntünün donup donmadığı, zaman damgası, parlaklık ve OK/RED oranındaki ani değişim izlenir (monitoring). Şüpheli girdide viyol RED sayılır ve operatöre alarm verilir (fail-safe). YZ hat hızını hiçbir durumda artıramaz.

3. **Confidence düştü:** Model "emin değilim" diyor. Eşik ne olmalı? Altında: dur / insana sor / fallback?
   Örneğin %95; kesin değer pilot verisiyle belirlenir. Eşiğin altındaki viyol RED sayılır ve operatöre sorulur (human override). Bu durum sık tekrarlanırsa hat yavaşlatılır ve klasik kontrole geçilir (fallback).

Karar tablosu — AI Fail-Safe Decision

Başarısızlık	Tanımladığınız güvenli davranış (hangi kavramla?)
Model yanlış sınıflandırdı	İkinci kontrol + örnekleme ile insan onayı (**human override**); emniyet zinciri YZ'den bağımsız kalır.
Girdi manipüle edildi	Kamera sağlığı ve OK/RED oranı izlenir (**monitoring**); şüpheli viyol RED olur ve alarm verilir (**fail-safe**).
Confidence düştü	Eşik altında RED + operatöre sor (**confidence threshold**); sık tekrarlanırsa klasik kontrole geç (**fallback**).

Bu föyün çıktısı **AI Fail-Safe Decision** → Evidence Pack **EP 03 + EP 15** başlığına oturur.